TLP:CLEAR Unrestricted public release.

CYBER THREAT INTELLIGENCE REPORT

PHP2Shell flaws exploited against exposed PAN-OS management interfaces; chained with Linux kernel bug in China-nexus attack

From **Cybersecurity Briefing** · 2026-10-28 to 2026-10-29 (last 24 hours) · Briefing generated 2026-10-29

REPORT ID	VERSION	HANDLING
CTI-20261029-03	1.0 · 2026-10-29 08:37 EDT	TLP:CLEAR
BRIEFING SECTION	**ORIGINAL PUBLISHED**	**LAST UPDATE**
United States	2026-10-21	2026-10-29
CVES	**ANALYST**	
CVE-2026-109618 (CVSS 9.2), CVE-2026-109619 (CVSS 9.2), CVE-2026-46300 (CVSS 7.8)	Nick Sturgeon	

VULNERABILITY | CRITICAL | ACTIVELY EXPLOITED | OVERALL CONFIDENCE: MODERATE

BOTTOM LINE UP FRONT

Palo Alto Networks updated its PHP2Shell advisory on 28 October 2026 to say attackers are now actively exploiting CVE-2026-109618 and CVE-2026-109619 (both CVSS 4.0 9.2) against PAN-OS management interfaces that can be reached from the internet [S1] [S5]. These are memory-safety flaws in PHP's handling of fatal and out-of-memory errors. After a request is aborted, stale state can let a later request leak memory or reach remote code execution without authentication [S9] [S11]. On PA-Series and VM-Series firewalls and Panorama, only the management web UI and XML API are affected, plus any dataplane interface with a management profile attached. GlobalProtect and Captive Portal are not affected [S5]. CISA added both PHP CVEs to KEV on 26 October, with a federal due date of 29 October. It added the Linux kernel flaw 'Fragnesia' (CVE-2026-46300, CVSS 7.8) on 28 October, due 31 October [S7] [S8] [S13]. EPSS rates both PHP CVEs at about 0.99999 and Fragnesia at about 0.10 (95.7th percentile) [S16].

Israeli firm Dream reported a campaign it assesses as China-nexus. The operator used FOFA to fingerprint about 19,000 internet-facing firewalls from one large vendor and narrowed them to about 240 targets in the U.S., Japan, Taiwan and South Korea. It then ran an automated chain of a custom PHP2Shell exploit followed by Fragnesia to get root, rooting 25 devices on 23-24 October [S2] [S3] [S4]. Dream did not name the vendor. Its description of an appweb management server running PHP 8.0.30 is consistent with PAN-OS, and press reporting suggests PAN-OS is the product, but neither Dream nor Palo Alto has confirmed

this [S1] [S3] [S4]. At a U.S. government-affiliated organization, the attacker did the following [S4]: - rooted one firewall (which then crashed) and a second firewall; - built a reverse SSH tunnel and used it to compromise an internal firewall management server; - from that server, decrypted an LDAP service account password, enumerated Active Directory, sprayed passwords, and tried to create backdoor user and machine accounts. Dream says 22 other rooted firewalls still had active webshells and that the tunnel was probably still live when it published [S3].

Fixed PAN-OS hotfix builds are listed for each release train in the 10.2, 11.1, 11.2, 12.1 and 12.2 branches. Several had release ETAs of 29-30 October [S5]. Upstream PHP is fixed in 8.5.12, 8.4.27, 8.3.36 and 8.2.35 [S9]. Fragnesia is fixed in Linux stable kernels including 5.10.257, 5.15.208, 6.1.174, 6.6.141, 6.12.91, 6.18.33 and 7.0.10 [S10]. Dream published host artifacts but no network indicators for this campaign. Examples are a tampered /etc/pam.d/su containing pam_permit.so, a reverse SSH tunnel kept alive by a systemd unit and an rc.local hook, and stolen HA, TLS and device keys. Several things remain unknown: which PAN-OS versions were hit, the operator IPs, and whether the AD backdoors worked [S4].

Recommended actions: - Today, remove internet access to PAN-OS and Panorama management interfaces or restrict it to trusted IPs or a jump host. - Enable Threat ID 543004 and the related Threat Prevention signatures. - Install the fixed hotfix as soon as it ships for your train [S5]. - Hunt any device whose management interface was exposed. Check for unknown PHP files, a changed /etc/pam.d/su, new systemd or rc.local entries, and outbound SSH from the management IP. - Treat confirmed hits as a full compromise. Rotate device keys, the LDAP bind account and SAML signing material, and audit AD for new accounts [S4]. - Separately, patch PHP on all web servers and patch the Linux kernel, because both flaws are in KEV and generic PHP2Shell scanning is widespread [S8] [S12].

Key judgments

VERY LIKELY · MODERATE CONFIDENCE

More internet-exposed PAN-OS management interfaces will be compromised through PHP2Shell over the next 30 days. The vendor confirms exploitation, several fixed builds were not yet released as of 29 October, and the Dream-observed operator already holds a list of about 19,000 fingerprinted devices. [S1] [S3] [S4] [S5]

VERY LIKELY · MODERATE CONFIDENCE

Some organizations whose firewalls were rooted before patching will keep attacker access after they patch. Patching does not remove the reverse SSH tunnel, the PAM tampering, persistence through systemd or rc.local, or the stolen device, HA and LDAP credentials. [S4]

LIKELY · LOW CONFIDENCE

Within the next 60 days, the same or other actors will adapt the PHP2Shell plus Fragnesia chain to other appliances and Linux web servers that embed PHP. Offsets are build-specific, which is likely to slow this but not stop it. [S3] [S4] [S12] [S13]

ROUGHLY EVEN CHANCE · LOW CONFIDENCE

Within 30 days, Palo Alto Networks or a major intelligence vendor will publicly tie the confirmed PAN-OS exploitation to the Dream-reported campaign and publish network indicators. [S1] [S4] [S5] [S6]

INDICATORS OF COMPROMISE

No source has published network indicators (operator IPs, domains or hashes) for the China-nexus PAN-OS campaign. The campaign entries below are host artifacts and behaviors from Dream's 26 October report, covering activity on 23-24 October 2026. The IPs, URLs, hashes, domains and user agents come from Arctic Wolf's 22 October report on generic PHP2Shell scanning and exploit attempts against PHP web servers. They are not linked to the PAN-OS campaign and may already be stale.

Type	Indicator (defanged)	Context	Provenance	First seen	Source
filepath	`/etc/pam.d/su`	Overwritten on rooted firewalls so that it contains pam_permit.so, which allows passwordless 'su root'. Dream reports the modified file was 774 bytes.	REPORTED	2026-10-23	[S4]
other	`pam_permit.so referenced in /etc/pam.d/su`	Content marker for the PAM tampering described by Dream. Any appearance of pam_permit in the su PAM stack on an appliance should be treated as compromise.	REPORTED	2026-10-23	[S4]
filepath	`/etc/rc.local`	Boot hook used to restart the reverse SSH tunnel after reboot.	REPORTED	2026-10-24	[S4]
other	`Unexpected systemd service wrapping a reverse SSH tunnel (8 forwarded ports)`	Persistence for the reverse SSH tunnel from the rooted firewall to operator infrastructure. The service name and ports were not published.	REPORTED	2026-10-24	[S4]
other	`103-byte PHP root webshell in a publicly accessible web directory on the firewall`	Planted after exploitation on 24 of 25 devices. Filename and path not published. The process ran as user 'nobody' in SELinux context httpd_t.	REPORTED	2026-10-23	[S2] [S4]
command	`id`	Run through the webshell to confirm root. Execution of id or similar recon by the web server user on an appliance is anomalous.	REPORTED	2026-10-23	[S4]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
http-request	`Large multipart POST bursts to the management web interface with oversized filenames and session data (about 900 MB total per target)`	Memory-exhaustion pattern that triggers the PHP OOM path. Targets were batched 5 at a time with an 1,800-second per-target timeout.	REPORTED	2026-10-23	[S3] [S4]
http-request	`multipart/form-data POST containing field PHP_SESSION_UPLOAD_PROGRESS`	PHP2Shell abuses PHP's session upload-progress handling. Seen in generic scanning and named as the mechanism in the PAN-OS appweb exploit. Not unique to malicious traffic.	REPORTED	2026-10-22	[S3] [S11] [S12]
other	`Unusually large or malformed PHPSESSID response cookie`	Response-side sign of the memory-disclosure stage. Heap contents come back in the session cookie. A honeypot operator reported an 800 KiB decoded cookie dump.	REPORTED	2026-10-24	[S11] [S13]
port	`22/tcp outbound from firewall management IP`	Dream reports a reverse SSH tunnel from the rooted firewall to operator infrastructure. Outbound SSH from a firewall management address to the internet is therefore a likely network sign. The actual port was not published, so the default SSH port is assumed.	DERIVED		[S4]
other	`iox`	Chinese-developed tunneling/port-forwarding utility found in the operator toolset.	REPORTED	2026-10-25	[S4]
other	`aiscan`	AI offensive-security platform on the operator infrastructure, configured with DeepSeek and Kimi models. Session logs contained Chinese-language prompts.	REPORTED	2026-10-25	[S3] [S4]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
other	`Palo Alto Threat ID 543004`	Vendor signature for PHP2Shell exploitation. Hits in PAN-OS threat logs indicate attempted exploitation. Related signatures are 97622-97625, 97643, 97647, 97649, 97652, 97653, 97656-97659, 97662-97664, 97670-97674 and 97676-97678.	REPORTED	2026-10-20	[S5] [S6]
ipv4	`92[.]118[.]112[.]100`	Generic PHP2Shell exploit attempts that ran id and uname and then used wget to fetch a payload. Not linked to the PAN-OS campaign.	REPORTED	2026-10-22	[S12]
url	`hxxp[://]92[.]118[.]112[.]100/nfs-setup`	Second-stage payload URL in generic PHP2Shell exploit attempts.	REPORTED	2026-10-22	[S12]
url	`hxxp[://]92[.]118[.]112[.]100/mountpoint`	Second-stage payload URL in generic PHP2Shell exploit attempts.	REPORTED	2026-10-22	[S12]
ipv4	`45[.]115[.]26[.]26`	Payload host referenced by a Monolog gadget-chain curl download in PHP2Shell session-poisoning attempts.	REPORTED	2026-10-22	[S12]
url	`hxxp[://]45[.]115[.]26[.]26:8000/cCmono`	Payload URL in a serialized Monolog SyslogUdpHandler chain. Arctic Wolf could not retrieve the file.	REPORTED	2026-10-22	[S12]
ipv4	`45[.]198[.]224[.]169`	Listed by Arctic Wolf as an indicator from PHP2Shell scanning and exploit activity.	REPORTED	2026-10-22	[S12]
ipv4	`5[.]175[.]189[.]76`	Listed by Arctic Wolf as an indicator from PHP2Shell scanning and exploit activity.	REPORTED	2026-10-22	[S12]
sha256	`e2529d4afa39ae4db2eb05d5176317c906289abf09660c75bdeec43e54c55aa3`	Potassium botnet-linked binary found on PHP2Shell payload infrastructure. Arctic Wolf did not confirm that it was downloaded through PHP2Shell.	REPORTED	2026-10-22	[S12]
sha256	`0c5486f06620e26e316f4b33f318b0d646d5e1133789331aa2fed012360d1486`	Potassium botnet-linked binary found on PHP2Shell payload infrastructure.	REPORTED	2026-10-22	[S12]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
domain	`thunder[.]godofthunder[.]st`	Potassium malware C2/update domain from Arctic Wolf's analysis of binaries on PHP2Shell payload infrastructure.	REPORTED	2026-10-22	[S12]
domain	`hackattackkaboom[.]botlesscucks[.]st`	Potassium malware C2/update domain from Arctic Wolf's analysis.	REPORTED	2026-10-22	[S12]
user-agent	`php2shell-scan/109618`	Self-identifying PHP2Shell scanner that sends about 63 KB multipart uploads with PHP_SESSION_UPLOAD_PROGRESS.	REPORTED	2026-10-22	[S12]
user-agent	`Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.0.0 Safari/537.36`	User agent listed with PHP2Shell exploit attempts. It is a common browser string, so use it only together with other indicators.	REPORTED	2026-10-22	[S12]
http-request	`POST /vuln.php?page=/var/lib/php/session/sess_p2sopchain...`	Session-path LFI probe with PHP code in the uploaded filename metadata. Look for requests that reference /var/lib/php/session/sess_ paths.	REPORTED	2026-10-22	[S12]
command	`system(base64_decode('aWQ=') )`	Command-validation payload (decodes to 'id') bracketed by RCE_noyzzg0YVLBU output markers.	REPORTED	2026-10-22	[S12]
command	`echo PHP2SHELL_CONFIRMED;cd /tmp; wget ...`	Second-stage delivery sequence seen in PHP2Shell exploit attempts. The wget target is truncated in the source.	REPORTED	2026-10-22	[S12]
other	`NUCLEIve97RH0fzh; P2SFNAME; P2SVALUE; RCE_noyzzg0YVLBU`	Output and canary marker strings in PHP2Shell scanner requests and responses. Useful for web log and WAF hunting.	REPORTED	2026-10-22	[S12]

Indicators are defanged (hxxp, [.], [@]) so they cannot be clicked. "Reported" means stated in a source; "Derived" means inferred by the analyst from the source material and should be validated before blocking.

TACTICS, TECHNIQUES & PROCEDURES (TTPS)

The operator searched FOFA for internet-facing firewall management interfaces and fingerprinted versions with a custom scanner (200 threads). It filtered to targets in four Pacific-region countries running a PHP 8.0.30-based appweb management server. An automated batch runner then sent large multipart POST floods that abuse PHP's session upload-progress path to force out-of-memory conditions. This turns stale request state into unauthenticated code execution as the web user ('nobody', httpd_t). Next, the runner used the Fragnesia page-cache write bug (CVE-2026-46300) to overwrite /etc/pam.d/su with pam_permit.so and gain root. It then planted a small PHP root webshell, checked it with 'id', and logged the result. At a high-value U.S. government-affiliated target, the operator did several more things. It stole HA, TLS and device private keys and opened a reverse SSH tunnel (via iox), kept alive by a systemd service and rc.local. It pivoted through the tunnel to exploit the internal firewall management server. From there it decrypted an LDAP bind password, enumerated AD, sprayed passwords (the domain had no lockout), tried to add backdoor user and machine accounts, and probed Keycloak SAML signing [S3] [S4].

Threat actor

Unnamed suspected China-nexus actor (Dream-tracked)

Attribution confidence: Low · **Motivation:** Likely espionage. Inferred from government-affiliated targeting and AD credential collection; not stated by the source. · **Suspected origin:** Suspected China (assessment by Dream)

Dream bases its China-nexus assessment on these points: target countries (U.S., Japan, Taiwan, South Korea), use of FOFA and iox, LLMs configured as DeepSeek and Kimi, a UTC+8 operator clock, and Chinese-language prompts. Dream also reports that Claude Code was installed on the attack infrastructure and that about 40 scripts showed signs of AI-assisted development. It did not confirm that AI wrote the exploit, and it did not assess the operation as fully autonomous. No named group has been linked [S3] [S4].

MITRE ATT&CK mapping

Tactic	Technique	Procedure observed	Detection opportunity
Reconnaissance	T1596.005 Search Open Technical Databases: Scan Databases	Used FOFA to find about 19,000 internet-facing firewall management interfaces. [S2] [S4]	Not detectable by the victim. Reduce exposure by removing management interfaces from the internet.
Reconnaissance	T1595.002 Active Scanning: Vulnerability Scanning	A custom version scanner with 200 concurrent threads fingerprinted about 5,000 responding devices. [S3] [S4]	Bursts of unauthenticated requests to management web UI paths from a single source. PAN-OS system and threat logs.

Tactic	Technique	Procedure observed	Detection opportunity
Initial Access	T1190 Exploit Public-Facing Application	A custom PHP2Shell exploit (CVE-2026-109618/109619) against the appweb PHP management server, using large multipart POSTs that abuse session upload-progress and trigger OOM. [S4] [S5] [S11]	PAN Threat ID 543004 and related signatures. Very large multipart POSTs to the management interface. HTTP 500 bursts. Oversized PHPSESSID cookies.
Privilege Escalation	T1068 Exploitation for Privilege Escalation	Fragnesia (CVE-2026-46300) XFRM ESP-in-TCP page-cache write used to get root from the 'nobody' web context. [S4] [S10] [S15]	File integrity changes to /etc/pam.d/su or setuid binaries. On general Linux hosts, unexpected esp4/esp6 module loads or ESP-in-TCP socket use by non-root processes.
Persistence	T1505.003 Server Software Component: Web Shell	A 103-byte PHP root webshell planted in a publicly accessible firewall web directory. [S2] [S4]	Look for unknown .php files in appliance web roots (via vendor tech-support data or forensic image). Web server processes spawning shell commands.
Persistence	T1556.003 Modify Authentication Process: Pluggable Authentication Modules	/etc/pam.d/su overwritten with pam_permit.so so that su root works without a password. [S4]	Integrity check of /etc/pam.d/su. Any pam_permit entry is malicious on appliances.
Persistence	T1543.002 Create or Modify System Process: Systemd Service	Reverse SSH tunnel wrapped in a systemd service. [S4]	Unexpected unit files under systemd directories. Long-lived outbound SSH sessions.
Persistence	T1037.004 Boot or Logon Initialization Scripts: RC Scripts	rc.local boot hook restarts the tunnel. [S4]	Changes to /etc/rc.local on appliances.
Credential Access	T1552.004 Unsecured Credentials: Private Keys	HA replication, SSL/TLS and device authentication private keys taken from the firewall filesystem. [S4]	Hard to detect after the fact. Assume theft on any rooted device and rotate the keys.

Tactic	Technique	Procedure observed	Detection opportunity
Command and Control	T1572 Protocol Tunneling	Reverse SSH tunnel (iox tooling) with 8 forwarded ports to DCs (LDAP, LDAPS, RDP), the management server, VPN infrastructure and a SOCKS5 proxy. [S4]	Outbound SSH from firewall management IPs. Internal connections to DCs or RDP that originate from the firewall management address.
Lateral Movement	T1210 Exploitation of Remote Services	The same PHP2Shell plus Fragnesia chain run through the tunnel against the internal firewall management server. [S3] [S4]	Large multipart POSTs to internal management servers from a firewall address. Threat ID 543004 hits on internal zones.
Credential Access	T1552.001 Unsecured Credentials: Credentials In Files	LDAP service account password decrypted from the management server configuration and hardcoded into scripts. [S4]	LDAP binds using the service account from unusual hosts or at unusual times.
Discovery	T1087.002 Account Discovery: Domain Account	Full LDAP enumeration of domain users and groups, plus ACL chain analysis. [S3] [S4]	High-volume LDAP queries from the firewall or management server address.
Credential Access	T1110.003 Brute Force: Password Spraying	Organization-themed passwords sprayed against every user. The domain lockoutThreshold was 0. [S3] [S4]	Event IDs 4625/4771 across many accounts from one source within a short window.
Persistence	T1136.002 Create Account: Domain Account	Tried to create a backdoor user in every OU, and a machine account by abusing the default MachineAccountQuota. [S4]	Event IDs 4720 and 4741, especially machine accounts created by non-admin accounts.
Credential Access	T1606.002 Forge Web Credentials: SAML Tokens	Tried to extract SAML signing keys and probed Keycloak authentication bypass. The IdP certificate validation setting was disabled. [S4]	Keycloak admin and audit logs for key export or config reads. Review SAML IdP certificate validation settings.

Detection & hunting

Queries are built from the reported behavior and indicators. They are untested; tune field names for your environment.

PAN-OS threat logs: PHP2Shell signature hits from public sources `SPLUNK SPL`

```
index=pan* sourcetype="pan:threat" (threat_id=543004 OR threat_id IN
(97622,97623,97624,97625,97643,97647,97649,97652,97653,97656,97657,97658,97659,97662,97663,97664,97670,
97671,97672,97673,97674,97676,97677,97678) OR threat_name="*upload*progress*" OR threat_name="*CVE-
2026-10961*")
| where NOT (cidrmatch("10.0.0.0/8",src_ip) OR cidrmatch("172.16.0.0/12",src_ip) OR
cidrmatch("192.168.0.0/16",src_ip))
| stats count min(_time) as first max(_time) as last values(threat_name) as sigs values(action) as
actions by src_ip dest_ip dest_port dest_zone
| convert ctime(first) ctime(last)
| sort - count
```

Based on the Unit 42 NGFW hunting approach. Field names follow the Splunk Add-on for Palo Alto Networks; adjust for your schema. Management-plane traffic appears only if it passes through a dataplane interface with a management profile or a protecting firewall.

Outbound SSH or long-lived sessions from firewall management addresses `KQL`

```
let MgmtIPs = dynamic(["<firewall-mgmt-ip-1>", "<firewall-mgmt-ip-2>"]);
CommonSecurityLog
| where TimeGenerated > ago(14d)
| where SourceIP in (MgmtIPs)
| where not(ipv4_is_private(DestinationIP)) or DestinationPort in (22, 389, 636, 3389)
| summarize Sessions=count(), Bytes=sum(SentBytes + ReceivedBytes), First=min(TimeGenerated),
Last=max(TimeGenerated) by SourceIP, DestinationIP, DestinationPort, DeviceVendor
| order by Sessions desc
```

Run against logs from an upstream device (another firewall, switch flow logs, or EDR on a core router) that can see traffic from the PAN-OS management interface. Any outbound SSH to the internet, or LDAP/RDP to domain controllers from a firewall management IP, needs explanation. Populate MgmtIPs from your inventory.

AD backdoor accounts and password spraying after an appliance pivot `KQL`

```
let window = 1h;
let Spray = SecurityEvent
| where TimeGenerated > ago(14d) and EventID in (4625, 4771)
| summarize Targets=dcount(TargetUserName), Attempts=count() by IpAddress, bin(TimeGenerated, window)
| where Targets > 20
| extend Signal="PasswordSpray";
let NewAccts = SecurityEvent
| where TimeGenerated > ago(14d) and EventID in (4720, 4741)
| project TimeGenerated, EventID, SubjectUserName, TargetUserName, Computer
| extend Signal=iff(EventID==4741, "MachineAccountCreated", "UserAccountCreated");
union Spray, NewAccts
| order by TimeGenerated desc
```

Pay closest attention to 4741 events where SubjectUserName is a service or LDAP bind account, and to sprays that come from firewall or management-server IPs. Thresholds need tuning.

PHP web worker spawning recon or download commands (general PHP servers) `SIGMA`

```
title: PHP Web Worker Spawns Recon Or Download Utility
status: experimental
logsource:
  product: linux
  category: process_creation
detection:
  parent:
    ParentImage|endswith:
      - '/php-fpm'
      - '/php'
      - '/php-cgi'
      - '/apache2'
      - '/httpd'
      - '/lsphp'
      - '/frankenphp'
  child:
    Image|endswith:
      - '/id'
      - '/uname'
      - '/whoami'
      - '/wget'
      - '/curl'
      - '/su'
  condition: parent and child
falsepositives:
  - Control panels or application code that legitimately shells out
level: high
tags:
  - attack.initial_access
  - attack.t1190
  - attack.t1505.003
```

For Linux PHP web servers with EDR or auditd. It does not apply to PAN-OS, where defenders cannot run agents. Based on Arctic Wolf-reported id/uname/wget payloads and Unit 42 post-exploitation hunting guidance.

REMEDIATION ACTIONS

Exposure

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Palo Alto Networks PAN-OS (PA-Series, VM-Series) and Panorama: management web UI / XML API	10.2, 11.1, 11.2, 12.1 and 12.2 builds below the listed hotfixes. Older unsupported versions are also affected.	12.2.4-h1; 12.1.4-h13, 12.1.7-h11, 12.1.10-h3; 11.2.4-h23, 11.2.7-h23, 11.2.10-h16, 11.2.13-h4, 11.2.16-h1; 11.1.4-h38, 11.1.6-h40, 11.1.7-h12, 11.1.10-h36, 11.1.13-h16, 11.1.16-h4; 10.2.7-h39, 10.2.10-h42, 10.2.13-h27, 10.2.16-h12, 10.2.18-h13 (some ETA 29-30 Oct 2026)	CVE-2026-109618, CVE-2026-109619	9.2 (CVSS 4.0); 5.2 when management access is limited to a jump box	0.99999 / 0.99999 (2026-10-28)	Yes (added 2026-10-26)	2026-10-29
PHP (php-src)	8.2.x < 8.2.35, 8.3.x < 8.3.36, 8.4.x < 8.4.27, 8.5.x < 8.5.12. Wiz reports versions back to 5.4 are affected; EOL branches have no upstream fix.	8.2.35, 8.3.36, 8.4.27, 8.5.12	CVE-2026-109618, CVE-2026-109619	9.2 (CVSS 4.0)	0.99999 / 0.99999 (2026-10-28)	Yes (added 2026-10-26)	2026-10-29

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Linux kernel (Fragnesia)	3.9 up to the fixed stable releases	5.10.257, 5.15.208, 6.1.174, 6.6.141, 6.12.91, 6.18.33, 7.0.10, 7.1+ (or distro-backported packages)	CVE-2026-46300	7.8 (CVSS 3.1)	0.10192 (95.7th percentile, 2026-10-28)	Yes (added 2026-10-28)	2026-10-31

Immediate (0–24 hours)

- Inventory every PAN-OS firewall and Panorama instance. Block internet access to the management web UI and XML API, including dataplane interfaces with a management profile. Allow only trusted internal IPs or a jump host. `IT OPS` [S5]
- Confirm Threat Prevention is licensed and on, with content version 9162 or later, so Threat ID 543004 and signatures 97622-97678 are active on inbound management traffic. Decrypt that traffic where feasible. `IT OPS` [S5] [S6]
- Install the fixed PAN-OS hotfix for each train as soon as it is released. Upgrade unsupported versions to a supported fixed build. `IT OPS` [S5]
- For any device whose management interface was reachable from the internet since 20 October, review threat logs for 543004 hits and look for outbound connections from the management IP. Collect a tech-support file and open a case with the vendor to check for unknown PHP files and changes to /etc/pam.d/su, systemd units or rc.local. `SOC` [S4] [S6]
- Patch internet-facing PHP servers to 8.5.12, 8.4.27, 8.3.36 or 8.2.35 (or a vendor backport) and restart the PHP workers. Block the Arctic Wolf-listed IPs and domains at the egress. `IT OPS` [S9] [S12]

Short term (1–7 days)

- If compromise is confirmed or suspected, isolate the device and rebuild or reimage it as the vendor directs. Rotate HA replication keys, SSL/TLS certificates and keys, device authentication keys, LDAP/RADIUS bind credentials, and admin passwords stored on the firewall or Panorama. `IT OPS` [S4]
- Treat the management server and every firewall it manages as compromised until verified clean if any one of them was rooted. `SOC` [S4]
- Audit AD for user and machine accounts created since 8 October. Review 4625/4771 for spraying from appliance or management IPs. Reset the LDAP service account. `SOC` [S4]
- Patch Linux kernels for CVE-2026-46300, prioritizing multi-user and internet-facing hosts. Where patching must wait, apply the Dirty Frag mitigations (disable esp4, esp6 and unused xfrm/IPsec modules). `IT OPS` [S10] [S15]
- Inventory other appliances and software that embed PHP (Cisco, Fortinet, Siemens and others are publishing advisories) and track vendor fixes. `IT OPS` [S9] [S14]

Long term

- Adopt a policy that network-device and hypervisor management planes are never reachable from the internet. Use a dedicated management VLAN with jump-host or ZTNA access, and audit it quarterly. `LEADERSHIP` [S5]
- Harden AD: set a non-zero lockoutThreshold, set ms-DS-MachineAccountQuota to 0, review ACLs and group membership, and enable IdP certificate validation on SAML providers such as Keycloak. `IT OPS` [S4]
- Send firewall management-plane logs and upstream flow data to the SIEM so appliance compromise can be detected without host agents. `SOC` [S4] [S6]
- Fund PHP version lifecycle management so no production workload runs an EOL PHP branch without a vendor backport. `LEADERSHIP` [S12]

Workarounds & compensating controls

- Where a PAN-OS fix is not yet available, route management traffic through a dataplane interface with a management profile so it can be inspected. Replace the inbound management certificate and enable decryption and Threat Prevention for it. `IT OPS` [S5]
- For PHP servers that cannot be patched immediately, use WAF or CDN virtual patching for PHP2Shell, such as provider rules or IPS signatures, and alert on oversized multipart uploads and PHPSESSID response cookies. `IT OPS` [S11] [S14]
- Block outbound SSH and arbitrary egress from firewall management interfaces. Permit only required update, licensing and logging destinations. `IT OPS` [S4]

Actions marked with an owner: SOC = security operations, IT Ops = system and network administration, Leadership = risk and communications decisions.

SOURCES

[S1] The Hacker News: Attackers exploit PHP2Shell flaws in Palo Alto Networks management interfaces
Published 2026-10-29 · `B2` Usually reliable, probably true
Briefing source. Its link from Dream's activity to PAN-OS is the outlet's own inference.

[S2] SecurityWeek: China-Linked Hackers Exploit PHP2Shell to Root Firewalls
Published 2026-10-28 · `B2` Usually reliable, probably true
Briefing source (reached via the SecurityWeek front page). Says two government-affiliated servers were compromised further; other reporting counts three systems.

[S3] The Hacker News: PHP2Shell attack roots 25 servers, breaches U.S. government-affiliated network
Published 2026-10-28 · `B2` Usually reliable, probably true
Summary of Dream research, with AI-tooling details and forum skepticism about exploit reliability.

[S4] Dream: Chained PHP2Shell exploit roots 25 servers
Published 2026-10-26 · **B3** Usually reliable, possibly true
Original researcher. Single-source campaign details; vendor and firmware versions redacted; no network IOCs.

[S5] Palo Alto Networks: CVE-2026-109618 Impact of Critical Vulnerabilities in PHP (CVE-2026-109618, CVE-2026-109619) on Palo Alto Networks Products
Published 2026-10-21 · **A1** Completely reliable, confirmed by other sources
Primary vendor advisory. Updated 2026-10-29. Confirms active exploitation against exposed management interfaces.

[S6] Unit 42 (Palo Alto Networks): Threat Brief: PHP2Shell (CVE-2026-109618 and CVE-2026-109619)
Published 2026-10-23 · **A2** Completely reliable, probably true
Hunting queries and signature list. Its 23 October update on agentic AI post-exploitation was retracted on 25 October.

[S7] CISA: CISA Adds Two Known Exploited Vulnerabilities to Catalog
Published 2026-10-28 · **A1** Completely reliable, confirmed by other sources
Adds CVE-2026-46300 (and VMware CVE-2026-41709).

[S8] CISA: Known Exploited Vulnerabilities Catalog (JSON feed)
Published 2026-10-28 · **A1** Completely reliable, confirmed by other sources
KEV dates and due dates for all three CVEs.

[S9] CVE Program (MITRE): CVE-2026-109618 record
Published 2026-10-21 · **A1** Completely reliable, confirmed by other sources
Affected and fixed PHP versions, CWEs, references. Its CVSS vector uses AT:P, while the PAN advisory uses AT:N.

[S10] CVE Program (MITRE): CVE-2026-46300 record (Fragnesia)
Published 2026-05-23 · **A1** Completely reliable, confirmed by other sources
Fixed kernel versions and commits. The CNA lists CWE-123 and CISA ADP lists CWE-456.

[S11] Wiz Research: PHP2Shell: PHP RCE
Published 2026-10-21 · **A2** Completely reliable, probably true
Original discoverers. Root cause, disclosure timeline, detection signals.

[S12] Arctic Wolf Labs: PHP2Shell: Critical PHP Vulnerabilities Enable Unauthenticated Remote Code Execution
Published 2026-10-22 · **B2** Usually reliable, probably true
Generic PHP2Shell scanning and exploit-attempt IOCs. Not linked to the PAN-OS campaign.

[S13] The Hacker News: CISA confirms active exploitation of PHP2Shell
Published 2026-10-27 · **B2** Usually reliable, probably true
KEV addition context, honeypot RCE report, related Broccoli2Shell flaw. Publication date inferred from content.

[S14] Help Net Security: What the PHP2Shell vulnerability means for Fortinet, Cisco and Palo Alto customers
Published 2026-10-22 · **B2** Usually reliable, probably true
Vendor status snapshot. Palo Alto at that time was not aware of exploitation.

[S15] The Hacker News: New Fragnesia Linux kernel LPE grants root
Published 2026-05-14 · **B2** Usually reliable, probably true
Fragnesia background and Dirty Frag mitigations.

[S16] FIRST: EPSS API scores for CVE-2026-109618, CVE-2026-109619, CVE-2026-46300
Published 2026-10-28 · **A2** Completely reliable, probably true
Model-based exploitation probability.

Grades use the Admiralty scale: letter = source reliability (A completely reliable to F cannot be judged), number = information credibility (1 confirmed to 6 cannot be judged).

MISCELLANEOUS

Timeline

Date	Event	Source
2026-05-13	Fragnesia (CVE-2026-46300) publicly disclosed on oss-security; PoC released by V12.	[S10] [S15]
2026-08-24	Wiz Research reports the PHP2Shell bugs to the PHP security team.	[S11]
2026-10-08	Dream-observed operator begins setting up the operation.	[S4]
2026-10-20	Palo Alto releases Threat ID 543004 (Frontier Virtual Patching) at 10:21 PM PT.	[S5] [S6]
2026-10-21	PHP releases 8.5.12, 8.4.27, 8.3.36 and 8.2.35; CVEs published; Palo Alto advisory published.	[S5] [S9] [S11]
2026-10-22	Arctic Wolf reports wide-scale PHP2Shell scanning and exploit attempts. Palo Alto says it is not aware of exploitation.	[S12] [S14]
2026-10-23	18:14 UTC: first U.S. government-affiliated firewall rooted; it crashes and does not recover.	[S3] [S4]

Date	Event	Source
2026-10-24	10:09 UTC: second government-affiliated firewall rooted and tunnel established. 11:35 UTC: internal management server compromised. 25 devices rooted in total.	[S3] [S4]
2026-10-25	Dream identifies the artifacts. Unit 42 retracts its 23 October update on agentic AI post-exploitation.	[S4] [S6]
2026-10-26	CISA adds CVE-2026-109618 and CVE-2026-109619 to KEV (due 29 October). Dream publishes its report.	[S4] [S8] [S13]
2026-10-28	CISA adds Fragnesia to KEV (due 31 October). Palo Alto updates its advisory to confirm active exploitation against exposed management interfaces.	[S1] [S7] [S8]
2026-10-29	Palo Alto advisory updated again; several fixed PAN-OS hotfixes due 29-30 October.	[S5]

Relevance to Indianapolis, Indiana & managed clients

Indiana organizations widely run Palo Alto firewalls and Panorama, including state agencies, county and city governments, school districts, universities, hospital systems, and manufacturers in central Indiana. The main local risk is management interfaces left open to the internet. This is common at small and mid-size businesses and at sites managed remotely by an outside IT provider, where admins sometimes allow 'any' instead of a fixed allowlist. Managed service clients should get the same-day treatment for every firewall in scope: an exposure check, allowlist enforcement, confirmation of Threat Prevention, and hotfix scheduling. Any device that was exposed should be hunted rather than just patched. Dream's victim set included a U.S. government-affiliated environment, and the post-compromise steps targeted Active Directory and SSO. Public-sector and healthcare entities that bind firewalls to AD through LDAP should therefore rotate those service accounts and check for new machine accounts. Separately, PHP runs on many local web servers, school and municipal sites, and line-of-business appliances. Combined with KEV-listed PHP and kernel flaws, this makes PHP and Linux patching a priority even where no Palo Alto gear exists. Indiana public entities that follow CISA guidance should note the KEV due dates of 29 and 31 October.

Intelligence gaps

- Dream has not named the firewall vendor or the firmware versions, and Palo Alto has not confirmed that its exploitation reports are the same campaign.
- No network indicators (operator IPs, tunnel endpoints, domains, webshell hash or path) have been published for the China-nexus campaign.
- It is unknown whether the AD backdoor accounts, password spray or SAML key extraction succeeded at the government-affiliated victim.
- It is unclear whether the 'internal firewall management server' was Panorama.
- Exploit reliability across PAN-OS builds is unknown. Forum commentary says offsets are build-specific, which may limit mass exploitation for now.
- Watch for: Unit 42 or Palo Alto IOCs and a compromise-assessment procedure; release of the remaining hotfixes; other vendors (Cisco, Fortinet, Siemens, ICS vendors) confirming exploitation of embedded PHP; and named attribution.

Other notes

- Palo Alto's stance has changed. On 22 October it said it was not aware of malicious exploitation and listed a CVSS-B 8.7 with moderate urgency; by 28-29 October it confirmed exploitation and rated the issue Critical/Highest urgency at 9.2 [S5] [S14].
- Victim counts differ by source. SecurityWeek says two government-affiliated servers were compromised further, while The Hacker News and Dream's timeline describe three systems (two firewalls and a management server), one of which crashed [S2] [S3] [S4].
- Unit 42 retracted its 23 October update describing agentic AI post-exploitation and now cannot tie that European government intrusion to these CVEs [S6].
- Dream reports that the operator's infrastructure contained AI tooling: Claude Code, aiscan with DeepSeek and Kimi, and AI-styled scripts. Dream did not confirm that AI wrote the exploit or that the operation was autonomous [S3] [S4].
- Cisco and Fortinet report affected or under-review products but no known exploitation as of 22-26 October. Siemens RUGGEDCOM APE1808 is listed as affected in the CVE record [S9] [S14].
- A related PHP flaw, CVE-2026-111497 ('Broccoli2Shell'), affects Windows PHP builds through cURL with automatic Brotli decompression (off by default). Patched builds were released on 26 October. Palo Alto says the separate CVE-2026-115560 does not affect PAN-OS [S5] [S13].
- The Arctic Wolf IOCs relate to generic opportunistic PHP2Shell activity, including Potassium botnet infrastructure. They are included for PHP web-server hunting, not as indicators of the China-nexus firewall campaign [S12].

CTI-20261029-03 v1.0 · Generated 2026-10-29 08:37 EDT from public reporting. Drafted with AI assistance and reviewed by Nick Sturgeon. Verify indicators and actions before operational use. Summaries are in the analyst's own words.

Back to the daily briefing.

TLP:CLEAR Unrestricted public release.